Class 2 - NotesApp Initial Threat Model

Yuchen Ye | Student ID 2023901708

Architecture and trust boundaries

Browser requests cross TB1 into Flask. Flask database operations cross TB2 into PostgreSQL. The admin ping feature and the mounted Docker socket cross TB3 into external or host-controlled resources.

Component	Security role
Browser	Untrusted client input and rendered output
Flask web container	Authentication, authorization and business logic
PostgreSQL	Accounts, grades and comments
External target / Docker host	Ping destination and privileged host resources

Key findings

- Spoofing: unsigned JWTs and weak credentials can impersonate users.
- Tampering: SQL injection, CSRF and unsigned exports permit undetected changes.
- Disclosure: HTTP, plaintext secrets and IDOR expose protected data.
- Elevation: command injection combined with root/Docker socket access can compromise the host.

Numbered logical flows

#	Flow
1	Login credentials
2	Account lookup
3	Account record
4	Session and redirect
5	Dashboard request
6	Student grade query
7	Grade rows
8	Dashboard HTML
9	Note API request
10	Note-by-id query
11	Selected note
12	Note JSON
13	Teacher page request
14	Teaching-data queries
15	Teaching data
16	Teacher HTML
17	Grade form
18	Grade write
19	Write result
20	Post-write redirect
21	Export request
22	Export query
23	Export rows
24	CSV download
25	Admin input
26	User/class database action
27	ICMP request
28	Admin result